

Sicurezza di base (utile a quiz e orale)

Anche se non è elenco separato nel bando Assistente, compare nelle prove affini PAT e rafforza cloud/reti/CAD.

Da ricordare

Password: mai in chiaro; hash iterativo con salt. Per autenticità del messaggio si firma con chiave privata.

1. Triade CIA

Confidenzialità, Integrità, Disponibilità: obiettivi fondamentali della sicurezza delle informazioni.

Confidenzialità: solo i soggetti autorizzati accedono alle informazioni (cifatura, controlli di accesso, classificazione, need-to-know). Integrità: i dati non sono alterati in modo non autorizzato o non rilevato (hash, firme digitali, controlli applicativi, log di modifica). Disponibilità: i servizi e i dati sono fruibili quando necessario (ridondanza, backup, anti-DDoS, manutenzione programmata, capacity).

Ogni controllo di sicurezza può essere letto rispetto a CIA. Esempio: TLS !' C e I del canale; cluster + backup !' D; firma digitale !' I e autenticità del documento; MFA !' protezione della C riducendo account takeover. Nella PA si aggiungono spesso autenticità, non ripudio e privacy (GDPR) come obiettivi collegati, senza sostituire la triade di base.

Apri quasi ogni risposta di sicurezza con CIA: orienta il valutatore e evita elenchi disordinati di tool. Schema: definisci le tre lettere in italiano, associa un controllo a ciascuna, fai un esempio PA (portale servizi, protocollo, posta). È la cornice che tiene insieme crittografia, attacchi e misure di igiene.

Glossario

CIA — Confidentiality, Integrity, Availability — Confidenzialità, Integrità, Disponibilità.

Non ripudio — Impossibilità per l'autore di negare di aver compiuto un'azione (es. firma qualificata).

In prova: Espandi l'acronimo in italiano e associa un controllo a ciascuna lettera.

Riferimenti: Fondamenti sicurezza informazioni

2. Crittografia simmetrica, asimmetrica e hash

Simmetrica = stessa chiave; asimmetrica = coppia pubblica/privata; hash = impronta non invertibile.

Crittografia simmetrica (AES e analoghi): stessa chiave per cifrare e decifrare; efficiente per grandi volumi di dati, ma pone il problema della distribuzione sicura delle chiavi. Asimmetrica (RSA, curve ellittiche): chiave pubblica per cifrare o verificare; chiave privata per decifrare o firmare. I protocolli reali (TLS) combinano le due (handshake asimmetrico + chiave di sessione simmetrica).

La firma digitale usa la chiave privata del firmatario; chiunque verifica con la pubblica. Per la confidenzialità verso un destinatario si cifra con la sua chiave pubblica (o si usa un canale ibrido). L'hash (SHA-256, ecc.) produce un'impronta a lunghezza fissa non invertibile: utile per integrità e per memorizzare password — ma solo con salt e KDF dedicati (bcrypt/scrypt/Argon2), non con hash «nudo» tipo SHA solo.

Schema d'esame da ripetere senza esitazioni: chiave privata !' firma (autenticità); chiave pubblica del destinatario !' cifra (confidenzialità). Password !' mai in chiaro, mai solo MD5/SHA, hash con salt + KDF. Domanda classica PAT: «Per autenticità firmo con...?» !' chiave privata.

Glossario

Salt — Valore casuale aggiunto alla password prima dell'hash per impedire rainbow table.

KDF — Key Derivation Function: deriva chiavi/impronte in modo computazionalmente costoso (es. per password).

Coppia di chiavi — Chiave pubblica (condivisibile) e chiave privata (segreta) della crittografia asimmetrica.

In prova: Domanda classica: «Per autenticità firmo con...?» !' chiave privata.

Riferimenti: CAD / eIDAS (firma) · Buone pratiche password hashing

3. Attacchi tipici

Phishing, ransomware, DDoS, SQL injection e XSS sono famiglie ricorrenti nelle prove e nella realtà PA.

Phishing: ingegneria sociale via email/messaggi/SMS per rubare credenziali o indurre azioni (bonifici, installazione malware); si mitiga con formazione, MFA, filtri antispam e verifica dei mittenti. **Ransomware:** cifra i dati e chiede riscatto; si mitiga con backup offline/immutabili, patching, least privilege, segmentazione e esercitazioni di restore. **DDoS:** saturazione di risorse di rete/servizio per negare disponibilità (colpisce la D della CIA).

SQL injection e XSS sono attacchi applicativi: il primo manipola query sul database; il secondo inietta script nel browser delle vittime (session hijacking, defacement). Difese: input validation, prepared statement, encoding in output, Content Security Policy, aggiornamenti framework e code review. Altri temi utili: credential stuffing, privilege escalation, attacchi alla supply chain.

In risposta elenca 4–5 attacchi con una riga di mitigazione ciascuno e, se possibile, abbina a CIA (phishing!C, ransomware!C/I/D, DDoS!D, injection!C/I): qualità da assistente operativo, non da elenco memorizzato vuoto. Evita dettagli di exploit: conta il ragionamento difensivo.

Glossario

Phishing — Inganno per indurre a rivelare credenziali o eseguire azioni dannose.

Ransomware — Malware che cifra dati e chiede riscatto per il ripristino.

XSS — Cross-Site Scripting: iniezione di script malevoli nelle pagine viste dagli utenti.

In prova: Abbina ogni attacco a CIA (phishing!C, ransomware!C/I/D, DDoS!D, injection!C/I).

Riferimenti: OWASP Top 10 · Buone pratiche cybersicurezza PA

4. MFA, least privilege, patching, backup

Controlli di igiene essenziali: autenticazione a più fattori, minimi privilegi, aggiornamenti e backup verificati.

MFA (Multi-Factor Authentication) combina almeno due fattori tra conoscenza (password), possesso (OTP, token, CIE) e inerenza (biometria): riduce drasticamente il rischio di password rubate o riusate. **Least privilege:** ogni utente e ogni processo ha solo i permessi necessari, per il tempo necessario (JIT ove possibile), evitando account admin «per comodità». **Patching** tempestivo chiude vulnerabilità note su SO, firmware, hypervisor e applicativi.

Backup: regola empirica 3-2-1 (tre copie, due tipi di supporto, una copia offsite); meglio se immutabili o offline contro ransomware. I backup vanno testati con restore periodici documentati: un backup non collaudato è un rischio nascosto che falsifica RTO/RPO. In cloud valgono le stesse logiche, con chiarezza su shared responsibility (cosa protegge il provider, cosa resta all'ente).

Quattro controlli = risposta completa a «misure minime di sicurezza» o «cosa faresti per mettere in sicurezza un servizio». Elenco d'oro: MFA + least privilege + patch + backup testato. Collega a misure AgID storiche e al quadro ACN senza inventare numeri di articolo non richiesti.

Glossario

MFA — Autenticazione a più fattori (es. password + OTP o CIE).

3-2-1 — Strategia di backup: 3 copie, 2 tipi di supporto, 1 copia offsite.

In prova: Elenco d'oro: MFA + least privilege + patch + backup testato.

Riferimenti: Misure minime di sicurezza ICT · Quadro ACN

5. Privacy by design e GDPR

Privacy by design/by default e misure tecniche organizzative adeguate sono doveri del titolare del trattamento.

Il Regolamento (UE) 2016/679 (GDPR) impone di progettare i sistemi proteggendo i dati personali fin dall'inizio (privacy by design) e con impostazioni predefinite restrittive (by default). Minimizzazione, limitazione delle finalità, cifratura, pseudonimizzazione, log di accesso, tempi di retention e diritti degli interessati (accesso, cancellazione, portabilità ove applicabile) sono esempi di misure tecniche e organizzative.

Nella PA il titolare del trattamento resta l'amministrazione; fornitori cloud/software agiscono spesso come responsabili del trattamento con contratto (art. 28 GDPR) e istruzioni documentate. Il DPO (Responsabile della protezione dei dati) supporta e sorveglia la conformità ma non «sostituisce» il titolare. In caso di data breach: notifica al Garante entro i termini e, se il rischio per gli interessati è elevato, comunicazione agli stessi.

Per l'assistente informatico: ogni nuovo applicativo implica valutazione di impatto (DPIA) ove richiesta, ruoli di accesso coerenti col least privilege, cifratura in transito (TLS) e a riposo ove adeguata, e cancellazione/anonimizzazione al termine della retention. In orale collega GDPR a misure concrete, non solo a principi astratti: la commissione valuta il passaggio dal «diritto» al «sistema».

Glossario

Privacy by design — Integrare la protezione dei dati nella progettazione di processi e sistemi sin dall'inizio.

Privacy by default — Impostazioni iniziali che limitano trattamento e accessibilità ai soli dati necessari.

DPO — Data Protection Officer / Responsabile della protezione dei dati.

In prova: Cita GDPR + by design/by default + esempio tecnico (minimizzazione, cifratura, log, retention).

Riferimenti: Regolamento (UE) 2016/679 (GDPR)